什么是信息泄露?

01 / 风险 | 个人信息、商业秘密、技术信息流向未经授权的对象

主要泄露途径

外部攻击：钓鱼、非法访问、利用漏洞，以及勒索软件攻击伴随的数据窃取。

内部人为因素

邮件误发、设备遗失、违规携出信息、访问权限过大、管理不完善。

云端与生成式AI的使用

云端公开设置错误、共享链接管理不当，以及未确认使用条款或公司内部规则就输入机密信息。

对企业活动的影响：直接损失

调查与恢复费用、业务中断、客户应对、损害赔偿等。

中长期损失

客户和合作伙伴信任下降、失去合同、技术外泄导致竞争力下降。

信息泄露不仅源于外部攻击，也会由日常操作失误引发。

防止泄露的主要系统

02 / 防御 | 结合认证、通信、终端、数据与监控的“纵深防御”

DLP | 数据防泄漏

识别机密信息，根据设置检测或限制邮件发送、复制到外部介质、上传至云端等行为。

EDR / XDR | 威胁检测与响应

EDR监控终端行为。XDR跨终端、邮件、身份等来源分析信息，协助调查与遏制威胁。

IAM / MFA | 身份、权限管理与多因素认证

IAM管理身份和访问权限。MFA使用多种认证因素，降低密码泄露后的非法登录风险。

SASE / ZTNA | 通信与访问保护

SASE整合网络与安全功能。ZTNA验证用户和设备，控制对所需资源的连接。

SIEM / SOC | 日志分析与监控运营

SIEM是集中收集、分析日志的机制。SOC是负责监控、分析和响应的组织或职能，两者角色不同。

各功能的覆盖范围与效果，因产品、设置和运营体制而异。

主要企业与主要领域

03 / 企业 | 列举代表性相关企业，顺序不代表排名或市场份额

日本企业

Digital Arts：网页、邮件过滤及信息防泄漏。

Trend Micro：终端、服务器保护及威胁检测与响应。

FFRI Security：威胁分析及日本国产终端防御产品。

Soliton Systems：认证、访问控制及终端安全防护。

HENNGE：云服务的认证与访问管理。

海外企业

Palo Alto Networks：网络保护、SASE及数据保护。

CrowdStrike：终端防御、威胁检测与响应及数据保护。

Zscaler：零信任连接、云端数据保护。

Microsoft：通过Entra进行身份管理，通过Defender应对威胁，通过Purview保护和治理数据。

保护信息的运营机制

04 / 运营 | 除引入产品外，还需完善日常管理与事故应对

掌握资产与信息

掌握终端、系统、存储位置，并按机密程度分类信息。明确谁能访问哪些信息。

持续落实基本措施

多因素认证、最小权限、安装更新、检查邮件与共享设置、持续员工培训。

生成式AI使用规则

梳理可输入的信息、允许使用的服务，以及数据保存、用于训练的条件。同时了解监控和控制能覆盖的范围。

检测与初期响应

监控可疑操作和通信，明确联系人与负责人。事故发生时调查影响范围，防止扩大并保全证据。

恢复与防止再次发生

验证备份和还原流程，为业务恢复作准备。分析事故原因，重新审视权限、设置和运营规则。

备份用于恢复准备，无法阻止信息泄露本身。